

Gestão de Cibersegurança

Universidade do Minho

2025/2026

Practical Lab Exercises #08

pg60986 — João Afonso Carneiro Araújo e Silva — MCS

pg59797 — Rui Pedro Ramos Carvalho — MCS

pg60307 — Tiago Leal Baganha — MCS

1. Caracterização dos Controlos

O primeiro controlo que vai ser abordado é o MFA, este controlo exige que os utilizadores comprovem a sua identidade com dois métodos de autenticação diferentes combinados, por exemplo password combinado com um código recebido no telemóvel. Este controlo mitiga ataques de phishing, acessos indevidos decorrentes de credenciais comprometidas e tentativas de intrusão em contas com privilégios elevados. Este controlo é essencial devido às equipas utilizarem os dispositivos pessoais e acederem remotamente aos servidores em outras regiões.

Este controlo é considerado fundamental de acordo com o NIST e a ENISA, logo é relevante para o negócio e faz parte de um enquadramento regulatório.

O benefício esperado com este controlo é uma forte redução do risco de acessos não autorizados, uma maior confiança dos clientes e parceiros e uma mitigação de tentativas de ataques direcionados a pessoas com elevados acessos. No entanto, este controlo pode não ser muito bem atendido inicialmente devido ao facto principalmente do aumento da dificuldade e do tempo dos utilizadores de acederem à informação da empresa e também uma carga maior de suporte do departamento responsável por esta mudança e manutenção do MFA

O segundo controlo que vamos abordar é a formação de sensibilidade em segurança, este controlo consiste em formação dos seus colaboradores destinada a melhorar os comportamentos deles mesmos perante riscos de phishing, engenharia social, exposição accidental de dados confidenciais. A mitigação centra-se no ser humano, responsável pela maioria dos incidentes de segurança.

Este controlo é fundamental porque responde à necessidade de reduzir os incidentes dos seus colaboradores.

A formação e sensibilização tem como benefício a redução de cliques em ataques de phishing, aumento da formação dos seus colaboradores e uma capacidade de identificar comportamentos suspeitos, por outro lado os colaboradores podem ver isto como uma perda de tempo.

O terceiro controlo é a gestão de configurações, esta medida estabelece normas e procedimentos para uma boa gestão de sistemas, servidores e aplicações da empresa. Este controlo reduz vulnerabilidades originadas por configurações inseguras e mudanças não autorizadas. Este controlo mitiga riscos associados a ambientes diferentes entre países, onde o controlo sobre as infraestruturas varia entre equipas.

O controlo de gestão de configurações é importante para cumprir os requisitos de governação e garantir a coerência entre as equipas.

Este controlo tem benefícios como a estabilização da infraestrutura, redução de falhas técnicas, melhoria de respostas a auditorias e diminuição de incidentes operacionais, embora necessita de recursos adicionais na equipa de IT.

[403 palavras]

2. Análise Organizacional e Política

O controlo de MFA envolve diversos stakeholders devido ao seu impacto direto na empresa e nos métodos de trabalho. A **equipa de vendas em Nova Iorque** é particularmente afetada devido à dependência de dispositivos pessoais e a necessidade de acessos rápidos. A **equipa de TI de Singapura** também visto que vão ter de dar suporte a toda a tecnologia do sistema de MFA. Tanto o **CTO** como o **CIO** desempenham papéis cruciais na validação técnica e na legitimação institucional da medida.

No caso do controlo de formação de sensibilidade, os principais stakeholders são o **departamento de RH**, responsável pela coordenação e comunicação das formações.

Por fim o controlo de gestão de configurações abrange sobretudo o **departamento de TI**, o **CTO** e indiretamente a unidade de **operações de negócio em Frankfurt**, que dependem de sistemas estáveis e podem contestar alterações que afetam processos sensíveis.

Parte interessada	Desinformada	Resistente	Neutra	Apoiadora	Lidera
CFO		X			
Divisão de Vendas (Nova Iorque)		X			
Infraestrutura de TI (Singapura)		X			
CTO		X			
Operações de Negócio (Frankfurt)		X			
RH				X	
CIO					X

O **CFO** constitui uma das principais fontes de oposição, motivado pela preocupação com custos e potenciais impactos negativos na produtividade.

A **Divisão de Vendas** apresenta resistência devido à perceção de que os controlos, em especial a MFA, introduzem fricção nos fluxos de trabalho que sustentam diretamente a performance comercial.

A equipa de **Infraestrutura de TI**, apesar de tecnicamente preparada, enfrenta limitações significativas de recursos.

O **CTO**, por sua vez, apresenta resistência de natureza política. A sua postura crítica em relação a iniciativas conduzidas pela gestão decorre de tensões internas, particularmente com o CIO.

As **Operações de Negócio em Frankfurt** resistem por motivos operacionais. Esta unidade, tende a ver controlos adicionais como entraves à fluidez das operações.

O departamento de **Recursos Humanos** é apoiador, tendo sido recentemente vítima de um ataque de phishing.

O **CIO** surge como líder inequívoco desta iniciativa, motivado tanto pela necessidade de recuperar a confiança na área tecnológica após a fuga de dados.

A cultura organizacional da empresa caracteriza-se por uma fragmentação geográfica e funcional acentuada. Equipas em continentes distintos operam com níveis variáveis de autonomia e maturidade tecnológica, o que leva a assimetrias na perceção da importância dos controlos de segurança.

A rivalidade entre o CIO e o CTO representa um risco político significativo. A falta de alinhamento entre estas lideranças pode resultar em atrasos, conflitos internos e resistência passiva na área técnica.

A pressão após a fuga de dados funciona como força para a adoção dos controlos, mas simultaneamente intensifica expectativas o que pode levar a ocorrer falhas na implementação. A recente reorganização da equipa de TI agrava as expectativas e receios para saber a competência operacional dos novos integrantes.

[449 palavras]

3. Estratégia de Implementação

A implementação dos três controlos será organizada ao longo de 12 meses, distribuídos por quatro trimestres, garantindo uma adoção progressiva, controlada e alinhada com a capacidade operacional da organização.

No **primeiro trimestre**, serão recolhidos requisitos técnicos e operacionais, mapeadas contas privilegiadas e identificado o inventário de sistemas críticos. Será iniciado um projeto de MFA com a **equipa de IT** e lançado o módulo inicial da formação de sensibilização, centrado nos riscos fundamentais para a empresa. Será também definido as configurações para o controlo de gestão de configurações.

Durante o **segundo trimestre**, a MFA será alargada a áreas administrativas e de suporte, para recolha de feedback antes de atingir grupos mais relevantes para o negócio. A formação avançará com módulos específicos sobre phishing e engenharia social, que são as duas atividades que a empresa consideram mais importantes.

No **terceiro trimestre**, a MFA será implementada em toda a organização. A formação incluirá simulações trimestrais de phishing para monitorizar o comportamento dos colaboradores. A gestão de configurações passará a utilizar ferramentas de automação para verificar conformidade.

No **quarto trimestre**, serão analisados incidentes ocorridos ao longo do ano, recolhidas lições aprendidas e ajustadas políticas internas. A maturidade de cada controlo será avaliada através dos indicadores definidos.

A negociação com partes interessadas resistentes requer abordagens diferenciadas e adaptadas às suas motivações.

O **CFO**, preocupado com custos e produtividade, deverá ser persuadido através de análises claras de custo-benefício, comparando o investimento necessário com os custos potenciais de incidentes de segurança.

O **CTO**, cuja resistência decorre de questões políticas e da necessidade de afirmar autoridade técnica, deverá ser envolvido desde o início na definição técnica dos controlos. Atribuir-lhe responsabilidade visível em componentes chave da implementação reforça o seu papel e reduz tensões com o CIO.

A **Divisão de Vendas**, preocupada com restrições à sua agilidade operacional, deverá ser abordada com soluções práticas para MFA em mobilidade, juntamente com garantia de suporte técnico prioritário.

As **Operações de Negócio de Frankfurt** precisam de ver demonstrado que os novos controlos não terão impacto negativo significativo nos seus processos.

A estrutura comunicacional deve adaptar a linguagem ao público-alvo, evitando o temos técnicos e explicando claramente cada controlo se afeta ou não as atividades diárias do departamento, sendo a comunicação segmentada por regiões e áreas funcionais, devido a diferenças culturais e operacionais entre os diferentes países.

A colaboração estreita com o departamento de RH será essencial, particularmente para garantir que a formação em segurança é percecionada como uma ferramenta de capacitação e não como mecanismo de monitorização.

Para medir a eficácia da implementação, serão definidos indicadores de sucesso para cada controlo. No caso do MFA, o principal fator é a percentagem de contas ativas com MFA, já no controlo de formação de sensibilização, as métricas podem incluir a taxa de conclusão das formações face o número de colaboradores, a evolução da taxa de cliques em emails de phishing. Por fim, no controlo de gestão de configurações será através da percentagem de sistemas conformes com os standards definidos neste momento pela empresa e a redução de incidentes provocados pela falta ou má configuração.

[510 palavras]